ADR-001 - Comunicação síncrona e fronteiras de autorização

Status: estado implementado documentado nesta revisão.

Contexto

O usuário precisa obter respostas da API e executar operações transacionais. Gateway, autenticação, RBAC e regras de negócio têm responsabilidades separadas.

Decisão registrada

Manter HTTP síncrono: HTTPS no Gateway, integrações Lambda para autenticação/Authorizer e VPC Link/NLB interno para a API. O código da aplicação usa portas/adaptadores e fluxo reativo. A autorização criptográfica do Gateway precede RBAC e propriedade de recurso na API. Management é um Service separado, sem rota pública. Grafana usa sua própria autenticação.

Consequências

O cliente observa imediatamente o status da operação. Falhas de rede/backend precisam de correlação e monitoramento. Não há contrato de fila/outbox/exatamente-uma-vez. SMTP é uma integração do adaptador da API e sua falha não deve ser confundida com erro de autenticação. Tokens, CPF e senhas ficam fora dos logs/documentos. Endpoints públicos são exceções explícitas.

Evidência

api-gateway.tf, scripts de smoke, controllers @RolesAllowed e portas/adaptadores da aplicação.